

Security+ 5.2 · Risk Management

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 5.2 — Risk Management (3:30)** · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Risk = Threat × Vulnerability × Impact on an asset. Risk assessment can be quantitative (monetary values) or qualitative (high/medium/low). Assessments can be ad-hoc (on demand) or recurring (periodic with updated risk register). The risk register is a living inventory of risks with owners and plans.

High-Yield Core Concepts Tested on Exam

- Risk = threat × vulnerability × impact on asset
- Quantitative assessment uses monetary values; qualitative uses high/medium/low
- Ad-hoc assessment: performed on demand
- Recurring assessment: periodic, keeps risk register updated
- Risk register: living inventory of risks with owners and mitigation plans

Exam Tips & Classic Scenarios

- 'likelihood x impact' = risk
- 'monetary value of risk' = quantitative
- 'high/medium/low risk' = qualitative
- 'periodic risk assessment' = recurring

Typical Exam Scenario: A company calculates the probability of an attack and the financial damage if it occurs. This is quantified risk. The exam may ask to identify the type of assessment or the formula.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 5.2 — Risk Management)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. RTO (Recovery Time Objective) measures:

- A)** How much DATA you accept losing
- B)** How much TIME the service can be down
- C)** The cost of the incident
- D)** The number of affected users

2. Corporate scenario (Risk Management): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.2), an analyst evaluates the following technical requirement: 'Risk = threat × vulnerability × asset impact'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Risk = threat × vulnerability × asset impact...
- D)** Allow shared access among administrators with generic credentials

3. Corporate scenario (Risk Management): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.2), an analyst evaluates the following technical requirement: 'Risk register: the living inventory of risks with owner and plan.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Risk register: the living inventory of risks with owner and plan...
- D)** Allow shared access among administrators using generic credentials

4. Corporate scenario (Risk Management): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.2), an analyst evaluates the following technical requirement: 'likelihood x impact'=risk. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'likelihood x impact'=risk...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

5. Corporate scenario (Risk Management): During a security review and compliance audit aligned with the CompTIA Security+ (SY0-701, Section 5.2) exam, an analyst evaluates the following technical requirement: 'probability of attack + financial damage if it occurs'=quantified risk'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: 'probability of attack + financial damage if it occurs'=quantified risk...

6. Corporate scenario (Risk Management): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.2), an analyst evaluates the following technical requirement: 'Risk = threat × vulnerability × asset impact'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Risk = threat × vulnerability × asset impact...
- D)** Allow shared access among administrators using generic credentials

7. Corporate scenario (Risk Management): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.2), an analyst evaluates the following technical requirement: 'Risk register: the living inventory of risks with owner and plan'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: Risk register: the living inventory of risks with owner and plan...

8. Corporate scenario (Risk Management): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.2), an analyst evaluates the following technical requirement: 'likelihood x impact' = risk. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'likelihood x impact' = risk.
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

9. Corporate scenario (Risk Management): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.2), an analyst evaluates the following technical requirement: "probability of attack + financial damage if it occurs"=quantified risk.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: 'probability of attack + financial damage if it occurs'=quantified risk....

10. Corporate scenario (Risk Management): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.2), an analyst evaluates the following technical requirement: 'Risk = threat × vulnerability × asset impact'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Risk = threat × vulnerability × asset impact...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) B — How much TIME the service can be down.

✓ **Why it's correct:** The correct answer is: how much TIME the service can be down. RTO (Recovery Time Objective) is a central metric in the Business Continuity Plan (BCP) and Disaster Recovery Plan (DRP), covered in the Business Continuity and Disaster Recovery domain of CompTIA Security+ SY0-701. It defines the maximum acceptable time to restore a service or process after an interruption, before the business impact becomes unacceptable. For example, if an e-commerce site sets an RTO of 2 hours, the recovery team must restore operations within 2 hours after the incident. RTO guides the choice of recovery strategies (hot site, warm site, cold site), backup frequency, and investments in redundancy. It is often confused with RPO, but while RTO measures downtime, RPO measures data loss.

✗ **Why the others are wrong:**

- *How much DATA you accept losing:* This is the definition of RPO (Recovery Point Objective), not RTO. RPO establishes the maximum amount of data that can be lost, measured in time (e.g., 15 minutes of transactions). It determines backup frequency: if the RPO is 1 hour, backups must occur at least every hour. RTO, on the other hand, focuses on service restoration time, not data loss. Confusing the two concepts leads to inadequate recovery strategies, as a low RPO does not guarantee a low RTO, and vice versa.
- *The cost of the incident:* The cost of the incident is a financial metric that quantifies direct and indirect losses resulting from an interruption (lost revenue, fines, productivity, reputational damage). Although it is an input to justify investments in continuity, it is not the definition of RTO. RTO is a time goal, not a monetary value. Using cost as the definition of RTO would divert focus from recovery planning, which needs clear temporal parameters to guide technical actions.
- *The number of affected users:* The number of affected users is an impact metric, useful for prioritization and communication, but it does not define RTO. RTO is a recovery time objective, regardless of the number of users. A service critical to few users may have a short RTO, while a service for many users may have a longer RTO, depending on business criticality. Therefore, this alternative does not correspond to the formal concept of RTO.

2) C — Implement the corresponding solution: Risk = threat × vulnerability × asset impact....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.2 (Risk Management): Risk = threat × vulnerability × asset impact.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

3) C — Implement the corresponding solution: Risk register: the living inventory of risks with owner and plan....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.2 (Risk Management): A risk register is a living document that inventories risks, assigns

owners, and outlines mitigation plans, serving as a central tool for ongoing risk management.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

4) B — Implement the corresponding solution: 'likelihood x impact'=risk....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.2 (Risk Management): 'likelihood x impact'=risk.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

5) D — Implement the corresponding solution: 'probability of attack + financial damage if it occurs'=quantified risk....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.2 (Risk Management): 'probability of attack + financial damage if it occurs'=quantified risk.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

6) C — Implement the corresponding solution: Risk = threat x vulnerability x asset impact....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.2 (Risk Management): Risk = threat x vulnerability x asset impact. This formula quantifies risk as the product of the likelihood of a threat exploiting a vulnerability and the potential impact on the asset, guiding risk assessment and mitigation strategies.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

7) D — Implement the corresponding solution: Risk register: the living inventory of risks with owner and plan....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.2 (Risk Management): Risk register: the living inventory of risks with owner and plan. A risk register is a document that records identified risks, their owners, and mitigation plans, and is regularly updated.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

8) B — Implement the corresponding solution: 'likelihood x impact' = risk..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.2 (Risk Management): 'likelihood x impact' = risk. Risk is quantitatively or qualitatively expressed as the product of the probability that a threat exploits a vulnerability and the magnitude of the resulting business impact.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and it breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

9) D — Implement the corresponding solution: 'probability of attack + financial damage if it occurs'=quantified risk.....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.2 (Risk Management): 'probability of attack + financial damage if it occurs'=quantified risk. Quantified risk involves assigning monetary values to potential losses and probabilities, often

using formulas like SLE (Single Loss Expectancy) and ALE (Annualized Loss Expectancy).

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

10) B — Implement the corresponding solution: Risk = threat × vulnerability × asset impact....

✓ Why it is correct: According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.2 (Risk Management): Risk = threat × vulnerability × asset impact.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.